LEXIGRID

Compliance Audits and Read-only Identity Evidence

Version 5.54.15 | Reviewed 2026-11-11

Shahryar Jahangir, Aniza Inc.

Procedures, examples, verification and operational limits. Complete commissioning on your deployment before serving customer traffic. Sample values are fictional; original keys and data must be preserved.

Contents

Compliance audits: applicability, implementation and effectiveness **3**

What the audit does . . . 3

1. Create the complete scope snapshot . . . 3

2. Collect supporting evidence . . . 3

3. Test and review every safeguard . . . 4

4. Independent final review . . . 4

5. Reports and provenance . . . 5

API reference . . . 5

Control-owner independence . . . 6

Read-only identity collection for compliance audits **6**

Microsoft Entra ID . . . 6

Active Directory . . . 7

Security and independent approval . . . 8

Compliance audits: applicability, implementation and effectiveness

Author: Shahryar Jahangir, Aniza Inc.

What the audit does

Compliance Audits creates a separate, versioned audit item for every imported requirement in the selected frameworks. It can also include controls outside those requirement mappings as separate safeguards with no invented standard attribution. The full catalogue is audited; the risk-matching AI shortlist is not used to limit audit coverage. Every item starts as undetermined, unknown and not tested.

The supported workflow can cover an entire imported ISO/IEC 27001, NIST SP 800-53, CJIS or other framework catalogue. Import the exact framework edition and its complete requirements first, review the extraction against the source standard, and establish actual control-to-requirement mappings. A framework identity alone is not a complete safeguard catalogue. Importing controls alone does not establish which framework they belong to. A selected framework with no requirements blocks finalization.

Catalogue completeness is an independent reviewer attestation supported by recorded evidence. LexiGrid cannot prove from an arbitrary uploaded list that no official standard provision was omitted. It does not distribute licensed standards or certify conformity.

The first identity integration provides four Entra checks and seven Active Directory checks. These are narrowly defined observations, not automated tests for every clause of every standard. Organizational, personnel, physical, contractual and other unsupported safeguards require actual documented procedures, observations and evidence. The engine must leave them not tested until that work is performed. An AI applicability match, implementation label, policy approval or file attachment alone cannot automatically establish operating effectiveness.

1. Create the complete scope snapshot

1. Open **Compliance Audits** in the navigation menu.

2. Expand **Create audit**. Enter a title and the systems, organizational boundary and observation period.

3. Select every in-scope framework and exact edition. There is no fixed number of selected frameworks or audit items.

4. Decide whether to include unmapped workspace controls as separate, unattributed safeguards.

5. Select **Create full catalogue snapshot**. Compare the total safeguards with the full source inventory.

The snapshot preserves source references, full requirement text, framework editions, source versions and explicitly mapped controls. New or changed requirements, frameworks or mapped controls are detected. Create a fresh audit snapshot when the source catalogue changes; prior audit evidence and authorship are preserved.

2. Collect supporting evidence

Expand **Record evidence and read-only identity observations**.

- **Upload encrypted audit evidence** records a supporting artifact of 1 byte through 10 MiB. Keep complete procedures, sampling details, source-system identity, observation period and results. Uploaded evidence remains operator-submitted until its provenance is independently verified.

- **Collect read-only Entra observations** uses an administrator-configured, current-workspace connector. Collection requests security-default settings, Conditional Access policies and sign-in observations from Microsoft Graph. Read failures, missing permissions and missing observations remain explicit gaps.

- **Evaluate read-only AD snapshot** accepts JSON from the supplied Windows/RSAT collector. It evaluates effective password policies, selected enabled-account flags and optional sampled security-event observations. Uploaded snapshots are not authenticated solely by a SHA-256 hash. Verify the collector origin, scope, capture time and actual source before relying on them.

A configuration check demonstrates only its stated setting. For example, an enabled MFA policy does not prove every account and application is protected. A sign-in observation is a bounded historical sample, not a live credential challenge or a penetration test. The screen reports each check's implementation/effectiveness dimension, criteria, observed counts and limitations. No check automatically marks an entire standard provision compliant.

Evidence is encrypted with the installation's existing evidence encryption provider and tenant-bound context. Downloads require an authenticated current-workspace session and are attachments; uploaded HTML is not executed. Artifact hashes and protected-payload integrity are retained. Raw Graph observations and submitted evidence are not sent to the risk AI by this audit workflow.

3. Test and review every safeguard

Find a reference using matrix search and the **Untested / unresolved** or **Failed effectiveness** filter. Previous and Next page through the complete matrix without discarding items.

Choose **Record safeguard test / review**. Record all three dimensions independently:

Dimension	Available conclusions	Meaning
Applicability	applicable, not applicable, undetermined	Whether the exact provision applies to the documented scope.
Implementation	implemented, partial, not implemented, unknown, not applicable	Whether the required safeguard has been put in place.
Effectiveness	passed, failed, not tested, insufficient evidence, not applicable	Outcome of the actual scoped operating test or reviewed evidence.

Enter a meaningful applicability/conclusion rationale, actual procedure and scope, and observed results. Select supporting evidence and exact technical checks. For operator-submitted files or AD snapshots, verify source provenance and record how it was checked. A hash establishes content identity, not the truth of the observation.

A tested pass requires an applicable and implemented safeguard with recorded evidence. Configuration-only checks cannot be used as a technical effectiveness pass. Technical passes require an effectiveness observation, and all selected checks must pass; failed or insufficient checks cannot silently be overridden as a technical pass. Current technical evidence must be no older than 30 days when reviewed. Manual evidence review records the human reviewer and their procedure and observations; it is not described as an independent machine measurement. Not-applicable exclusions also require supporting evidence and provenance verification.

Draft reviews may remain undetermined or not tested. Saving such a review increases the reviewed count but does not increase the passed count. Record failures and gaps honestly; do not invent observations to complete a matrix.

4. Independent final review

A tenant administrator, platform administrator or auditor other than the audit creator must finalize the audit. Risk managers may create and test audits but cannot perform final approval. The reviewer must:

1. Compare every framework catalogue against its complete source edition.

2. Select recorded completeness evidence and write the completeness review statement.

3. Resolve every safeguard's applicability and every applicable safeguard's implementation and tested effectiveness.

4. Confirm the catalogue has not changed since the snapshot.

5. Choose **Finalize reviewed audit**.

Unresolved or untested applicable safeguards block finalization. A completed audit may contain failed tests and implementation findings; completion does not mean compliance. A scope with only supported not-applicable exclusions is reported as having no applicable safeguards, rather than as proven effective controls.

Finalization requires the existing audit-signing configuration. It binds the full scope, source catalogue, reviewers, decisions and protected-evidence identities to a signed audit event. The finalized snapshot becomes read-only. Changes to source records are reported without rewriting historical conclusions. A mismatch in the stored snapshot, encrypted evidence or signed history marks the conclusion unverified and must be investigated. Do not treat snapshot integrity verification as proof that the underlying control is effective.

5. Reports and provenance

Use **Export JSON**, **Export PDF** or **Export CSV** from the audit. Reports retain scope, framework editions, every source reference, the three dimensions, actual procedures and observations, reviewer attribution and evidence references. JSON includes check observations and metadata; PDF includes the full safeguard/review narrative and summary; CSV provides one row per safeguard with the review dimensions and evidence references. Raw protected artifacts are downloaded separately through authenticated evidence downloads.

An open audit exports as incomplete. Untested and insufficient-evidence outcomes are preserved, not converted to passes. Finalized reports include the reviewer, finalization time, snapshot digest, integrity status and scoped conclusion. The software does not claim certification, exhaustive external-standard mapping or live system coverage that was not observed.

API reference

All routes are authenticated and tenant-scoped. Substitute actual IDs.

- `POST /api/compliance/audits`: title, scope, framework_ids, include_unmapped_controls.

- `GET /api/compliance/audits?limit=100&offset=0`: saved audits, with total and pages.

- `GET /api/compliance/audits/{id}`: complete snapshot, counts, source-change status, evidence metadata and all safeguard items.

- `POST /api/compliance/audits/{id}/evidence-files`: multipart file upload.

- `GET /api/compliance/audits/{id}/evidence/{evidence_id}/download`: authenticated protected-artifact download.

- `POST /api/compliance/audits/{id}/collect-entra`: connector_id.

- `POST /api/compliance/audits/{id}/active-directory-snapshots`: snapshot plus organization-selected password/lockout thresholds.

- `PUT /api/compliance/audits/{id}/items/{item_id}/review`: current item version, separate dimension states, method, reason, procedure, observations, evidence_ids, check_refs and provenance review.

- `POST /api/compliance/audits/{id}/finalize`: current audit version, catalogue_complete_attested, completeness_statement and completeness_evidence_ids.

- `GET /api/compliance/audits/{id}/export/json`, `/pdf` or `/csv`.

- `POST /api/compliance/connectors/entra`: administrator-only encrypted connector configuration.

- `GET /api/compliance/connectors`: connector metadata for audit operators; secrets are not returned.

- `POST /api/compliance/connectors/{id}/disable`: administrator-only collection disablement; prior audit evidence is preserved.

- `GET /api/compliance/collectors/active-directory.ps1`: read-only collector download.

The exact request schemas are available in the installation's `/docs` interface. Stale versions and finalized-audit writes return conflicts. Cross-workspace audit, item, connector and evidence IDs are not accepted. Existing risk assessment and Requirements APIs remain available.

Control-owner independence

For conclusive reviews and finalization, an identified control owner (user ID/email) cannot attest their own control. Owners may save an unresolved draft. Current control versions are locked and compared with the snapshot before a conclusive decision. Changed controls require a fresh snapshot. Existing finalized snapshots are preserved. Free-text group names are not a directory identity; this check does not replace organization-specific independence governance or fine-grained permissions.

Read-only identity collection for compliance audits

Author: Shahryar Jahangir, Aniza Inc.

Microsoft Entra ID

Create a dedicated app registration in the directory to be audited. Assign the Microsoft Graph **application** permissions **Policy.Read.All** and **AuditLog.Read.All**, and have the authorized directory administrator grant consent. LexiGrid does not create the registration, grant consent or expand directory permissions itself. Keep SSO and audit-collection registrations separate. Follow your organization's credential-management procedures.

In **Compliance Audits -> Configure read-only Microsoft Entra connector**, enter a recognizable name, the directory tenant ID, application client ID, client secret and a sign-in lookback of 1-30 days. A tenant or platform administrator saves this configuration. The credential is encrypted with the existing local, Vault or Conjur evidence-encryption provider and is never returned by the connector API. To rotate, configure the replacement connector, verify authorized reads and disable the old connector. Disabling collection preserves historical evidence.

This version supports commercial Microsoft endpoints only. The token request uses the selected directory at login.microsoftonline.com; Graph reads use graph.microsoft.com. Government and China cloud endpoints are not configured by this connector. Disconnected installations can use reviewed offline evidence and AD snapshots; Entra collection requires approved outbound HTTPS connectivity. No collection runs on startup or merely when a risk is opened.

On a scoped audit, choose the connector and select **Collect read-only Entra observations**. The collector obtains a client-credentials token and issues GET requests for:

- `/v1.0/policies/identitySecurityDefaultsEnforcementPolicy`

- `/v1.0/identity/conditionalAccess/policies`

- `/v1.0/auditLogs/signIns`, restricted to the selected observation period and required fields.

The collector follows all returned pages for an approved resource. It refuses redirects, foreign pagination hosts, changed resource paths and repeated page links. It uses a 20 MiB collection byte budget; exceeding it produces an incomplete-collection gap, not a partial passing sample. A shorter observation period may be required. Credentials are sent only to Microsoft's fixed token endpoint and bearer tokens only to approved Graph resources. HTTP failures are reported without raw credential-bearing provider responses.

The four initial checks are:

Check	Dimension	Precisely what is tested
Security defaults configuration	Implementation	The retrieved isEnabled flag is true.
Enabled MFA / authentication-strength policy	Implementation	At least one enabled policy includes the specified grant; scope and exclusions still need review.
Legacy-client blocking policy	Implementation	An enabled policy blocks exchangeActiveSync and other legacy clients; actual coverage is not inferred.
MFA reported on successful interactive sign-ins	Effectiveness observation	All successful interactive events in the retrieved period report multiFactorAuthentication; missing observations are insufficient evidence.

Sign-in licensing, permissions, retention and service availability determine which observations can be retrieved. A configuration check passing is not an entire-control compliance pass. Event results are bounded historical observations reported by Entra, not independent credential challenges. Review policy conditions, exceptions, authentication-strength definitions, unobserved accounts/applications and actual scope before drawing a control conclusion.

Microsoft references: security defaults API (https://learn.microsoft.com/en-us/graph/api/identitysecuritydefaultsenforcementpolicy-get?view=graph-rest-1.0), Conditional Access policies API (https://learn.microsoft.com/en-us/graph/api/conditionalaccessroot-list-policies?view=graph-rest-1.0), sign-in API and permissions (https://learn.microsoft.com/en-us/graph/api/signin-list?view=graph-rest-1.0).

Active Directory

Download **Collect-LexiGridAD.ps1** from Compliance Audits. Run it on an authorized Windows host with the RSAT ActiveDirectory PowerShell module and read access to the specified domain. Optional Security event retrieval also needs appropriate read access to the chosen server's Security log. Do not grant directory-write privileges for this collector or bypass your organization's script-signing/execution policy.

Example using fictional hostnames; use a new output filename:

```
.\Collect-LexiGridAD.ps1 -Server dc01.example.invalid -OutputPath .\LexiGrid_AD_Snapshot.json
-IncludeSecurityEvents
```

The script uses Get-ADDomain, Get-ADDefaultDomainPasswordPolicy, Get-ADUser and Get-ADUserResultantPasswordPolicy. It inventories enabled accounts and their effective policies, including fine-grained policies rather than assuming the domain default applies to everyone. Selected account flags are collected; account identities are hashed, credentials and security-event message bodies are not exported. Missing attributes remain unknown. Optional Get-WinEvent reads are limited to the explicitly selected server and stated observation period. AD settings are not modified. The script refuses to overwrite an existing evidence file.

Upload the generated JSON using **Evaluate read-only AD snapshot**. Set the password-length and lockout thresholds to the organization's documented criteria. These defaults are not universal NIST, ISO or CJIS requirements. The collector checks:

- effective minimum password lengths;

- reversible-encryption settings;

- effective account-lockout thresholds;

- password-required flags for enabled accounts;

- Kerberos preauthentication flags;

- unconstrained-delegation flags requiring review;

- optional sampled successful-logon event observations.

An incomplete collection or missing/wrongly typed attribute cannot become a pass. Snapshots older than 30 days remain insufficient evidence. A local hash proves content identity only: an uploaded snapshot is operator-submitted, not independently authenticated by LexiGrid. Independently verify the collector, source-system identity, observation period and relevant access before recording a tested conclusion. Sampled logon events establish only the presence of those observations, not complete audit retention, alerting, MFA or every domain controller's protection.

The collector's syntax and runtime were verified in Microsoft PowerShell with isolated mock directory commands. A real Windows RSAT/AD connection must be validated in the client environment; no real client AD domain was accessed during release testing.

Microsoft references: Get-ADDefaultDomainPasswordPolicy (https://learn.microsoft.com/en-us/powershell/module/activedirectory/get-addefaultdomainpasswordpolicy?view=windowsserver2025-ps), Get-ADUserResultantPasswordPolicy (https://learn.microsoft.com/en-us/powershell/module/activedirectory/get-aduserresultantpasswordpolicy?view=windowsserver2025-ps).

Security and independent approval

Only existing tenant/platform administrators configure or disable Entra credentials. Tenant/platform administrators, risk managers and auditors create scopes, collect evidence and record reviews. Ordinary viewers can read audit results in their own workspace but cannot run collection or alter conclusions. Finalization requires an authorized administrator or auditor different from the audit creator, the existing audit-signing configuration, catalogue-completeness evidence and no unresolved applicable safeguards.

Evidence/configuration uses the existing encryption provider with tenant- and record-bound context. No secret-key rotation, authentication policy change, schema migration or SSO reconfiguration is required by this feature. Operation logs retain IDs, hashes, states and safe collection failures; they do not copy secrets, raw evidence files or raw Graph observations. Signed finalization detects changes to scope, reviews or protected evidence without rewriting the existing immutable audit controls.

For integrity mismatches, stop relying on the conclusion and investigate the signed audit history and protected source evidence. Preserve prior data and keys. Reopening a finalized audit by changing its stored lifecycle field cannot bypass the signed finalization event through the API. Create a new audit snapshot for changed source catalogues or new testing periods.